

Mediroza General Hospital Black Box Penetration Testing Report

By Jeffrey Obi

Executive Summary

A black-box penetration test is a security examination carried out by an ethical hacker. It involves simulating the conditions and activities of an external attacker with the intention of understanding the target's vulnerabilities. This examination was conducted on the Mediroza General Hospital domain (**medirozahospital.com**) with written permission from the owner. The test proved successful, as weaknesses were discovered on the domain and sensitive data was accessed.

Scope and Methodology

Target

The target was the Mediroza General Hospital domain (**medirozahospital.com**).

Tools

Tools used include:

1. Machine: Lenovo Thinkpad
2. Operating System: Windows
3. Operating System: Kali Linux
4. Linux Tools: whois, whatweb, nslookup, curl, wafw00f, DNSrecon, & theHarvester.
5. OSINT tool: Maltego
6. Domain Scanner: Zenmap
7. Browser: Firefox
8. PDF Password Hash Extractor: Networkwalk's Hash Calculator
9. PDF Password Cracker: Networkwalk's Password Cracker
10. Soda PDF: PDF viewer installed on Windows machine.

Approach

The systemic approach employed for the test involved the following procedure:

1. Reconnaissance
2. Scanning
3. Gaining access
4. Extraction
5. Cracking

Limitations

I encountered the following limitations while undertaking this project:

1. Inconsistent security configurations across login portals.
2. Inconsistent permissions for accessible files and directories within hidden paths.
3. Backend system defended against brute-force attacks.

Findings & Proof of Exploitation

As proof of exploitation, the following data was found from the black-box penetration test.

1. Patient Reports

- a. Pathology Report - S. Dlamini

**Mediroza**
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Sipho Dlamini**

Report Date: **2024-11-04**

Patient ID: **MG-P-10231**

Referring Dr: **Dr. Anita Naicker**

Date of Birth: **1984-06-12**

Specimen: **Whole blood (EDTA)**

Gender: **Male**

Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	$\times 10^9/L$	4.0 - 11.0	HIGH
Platelet Count	245	$\times 10^9/L$	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Screenshot of the **patient_report_1.pdf** file showing its contents.

- b. Pathology Report - P. Reddy



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Priya Reddy** Report Date: **2024-11-05**
Patient ID: **MG-P-10244** Referring Dr: **Dr. Johan van der Merwe**
Date of Birth: **1991-02-28** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Screenshot of the **patient_report_2.pdf** file showing its contents.

c. Pathology Report - E. Thompson



14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Emily Thompson** Report Date: **2024-11-06**
Patient ID: **MG-P-10258** Referring Dr: **Dr. Ahmed Kara**
Date of Birth: **1978-09-03** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1205**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Screenshot of the **patient_report_3.pdf** file showing its contents.

2. Staff and shareholder details

a. Staff Salaries (in Rand):

- | | |
|--------------------------------------|------------------------------|
| i. Dr. Rajesh Naidoo: 138000 | v. Dr. Ahmed Kara: 128000 |
| ii. Sarah Botha: 152000 | vi. Dr. Yusuf Cassim: 74000 |
| iii. Dr. Johan van der Merwe: 160000 | vii. Michael Roberts: 96000 |
| iv. Dr. Anita Naicker: 132000 | viii. Susan Pretorius: 32000 |
| | ix. Jameel Malik: 58000 |

x.	Thabo Molefe: 46000	xxi.	Dr. Suresh Moodley: 130000
xi.	Nomvula Khumalo: 34000	xxii.	Dr. Fatima Patel: 118000
xii.	Lerato Mokoena: 33000	xxiii.	Nisha Singh: 48000
xiii.	Bongani Ndlovu: 35000	xxiv.	Dr. Vikram Chetty: 135000
xiv.	Zanele Mahlangu: 42000	xxv.	David Smith: 52000
xv.	Kagiso Sithole: 61000,	xxvi.	Karen O"Conno: 29000
xvi.	Naledi Zulu: 26000	xxvii.	James Wilson: 27000
xvii.	Themba Nkosi: 44000	xxviii.	Linda Fourie: 19000
xviii.	Palesa Radebe: 43000	xxix.	Peter van Wyk: 38000
xix.	Deepak Pillay: 41000	xxx.	Andile Mbeki: 21000
xx.	Kavitha Govender: 35000		

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.aidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154085',42000,'2013-03-25'),
(15,'Kagiso Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165086',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;
```

Screenshot of the SQL file showing staff details, including salaries.

b. Shareholder details:

ID	Shareholder Name	Share Percent (%)	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0	120,000	Ordinary
4	Reddy Family Trust	11.0	110,000	Ordinary
5	Thabo Molefe	10.0	100,000	Ordinary
6	Sarah Botha	9.0	90,000	Ordinary
7	Dr. Ahmed Kara	8.0	80,000	Preferential

ID	Shareholder Name	Share Percent (%)	Shares Held	Share Class
8	Naledi Zulu	7.0	70,000	Ordinary
9	Michael Roberts	6.0	60,000	Ordinary
10	Dr. Vikram Chetty	4.0	40,000	Preferential

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders`
(`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

Screenshot of the SQL file showing shareholder details.

Risk Rating

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Back-end architectural data exposed	Wrong and correct username guessing revealed account enumeration	Attackers may exploit the back-end	High
2	Unsecure ports open	Ports with corresponding unencrypted protocols appear open	Provides exploitable entry points on the web server	Medium
3	User authentication flaw exposed	Improper input validation, where login submission with empty password box was permitted	May ease brute-forcing attacks	High
4	SQL misconfiguration	SQL injection test returned a visible database error message	Vulnerability to SQL injection attacks	High
5	Restricted and sensitive records unprotected	Instructions for external crawlers revealed hidden but unprotected paths	Attackers may infiltrate the directories and steal exposed sensitive data	High

Recommendations and Remediation

In response to identified risks and vulnerabilities, the following remediations are recommended.:

1. Only the ports for encryption-secured protocols should be open.

2. Web frontend and backend should be configured with input validation and input sanitation.
3. Implement alternatives to a robots.txt file which don't enumerate hidden/restricted paths.
Examples include adding a **X-Robots-Tag** in the HTTP response header, or adding a HTML Meta Tag to the specific page/path you want restricted.
4. Sensitive and retained database files should be encrypted.